IqraSec Academy | WAPT Phase 1

Task 4: Web Vulnerabilities – Path Traversal

Intern name	Maryam Batool
Report title	Task 4: Common Web Vulnerabilities — Path Traversal
Rooms / Labs covered	PortSwigger Web Security Academy — File path traversal, simple case
Date completed	1 November 2026

1. Lab Name

File path traversal, simple case (PortSwigger Web Security Academy).

2. Objective

To identify and exploit a path traversal vulnerability in a product image endpoint, and use it to read an arbitrary file from the server's filesystem outside the intended image directory.

3. Vulnerability / Concept

- The application serves product images through an endpoint of the form /image?filename=<name>, which reads the named file from a fixed images directory on the server.
- Because the filename parameter is passed straight to the filesystem without validating that it stays inside the intended directory, an attacker can supply directory traversal sequences (../) to walk up out of the images folder and reach other files on disk.
- This is a simple case: no filtering or encoding is applied to the filename parameter at all.

4. Testing Approach

- Opened a product page and noted that its image was loaded via /image?filename=45.jpg, confirming the application takes a filename directly as a request parameter.
- Requested that same endpoint on its own in the browser to confirm it returns the raw image file content for a given filename.
- Changed the filename parameter to ../../../etc/passwd and viewed the page source to force the server to return the file as plain text rather than trying to render it as an image.
- The response contained the full contents of /etc/passwd, including application user accounts such as peter, carlos and academy, confirming the traversal succeeded and the lab was marked Solved.

5. Evidence / Screenshots

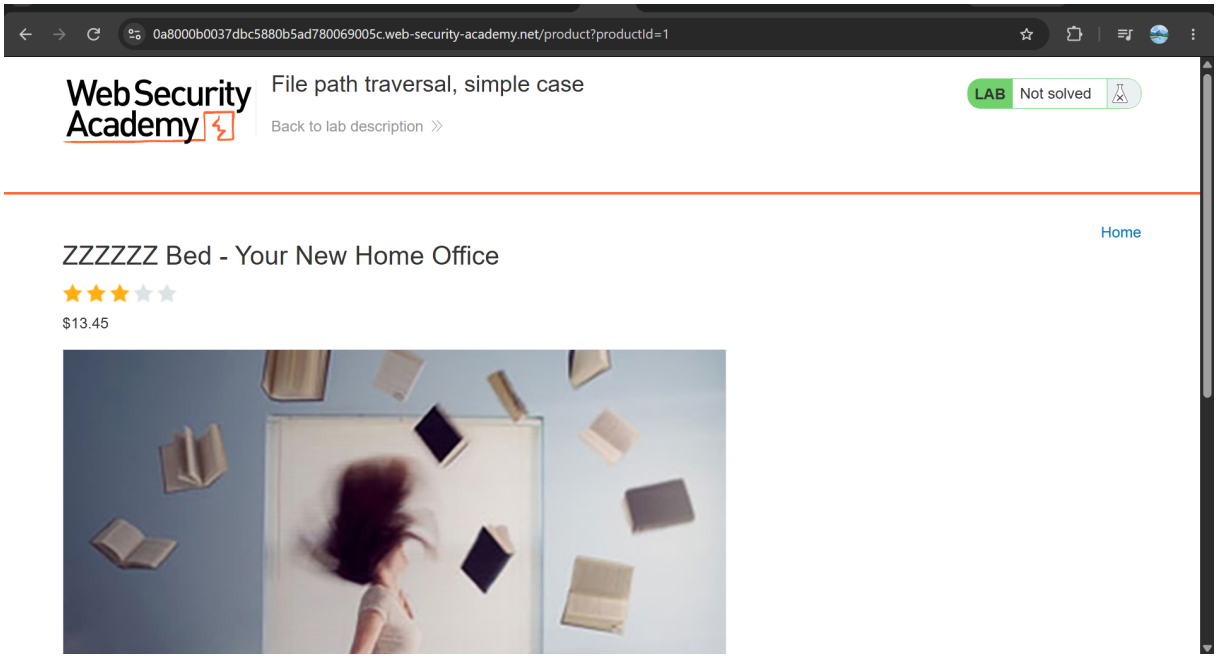


Figure 1: *Product page loading its image via /image?filename=45.jpg; lab Not solved.*

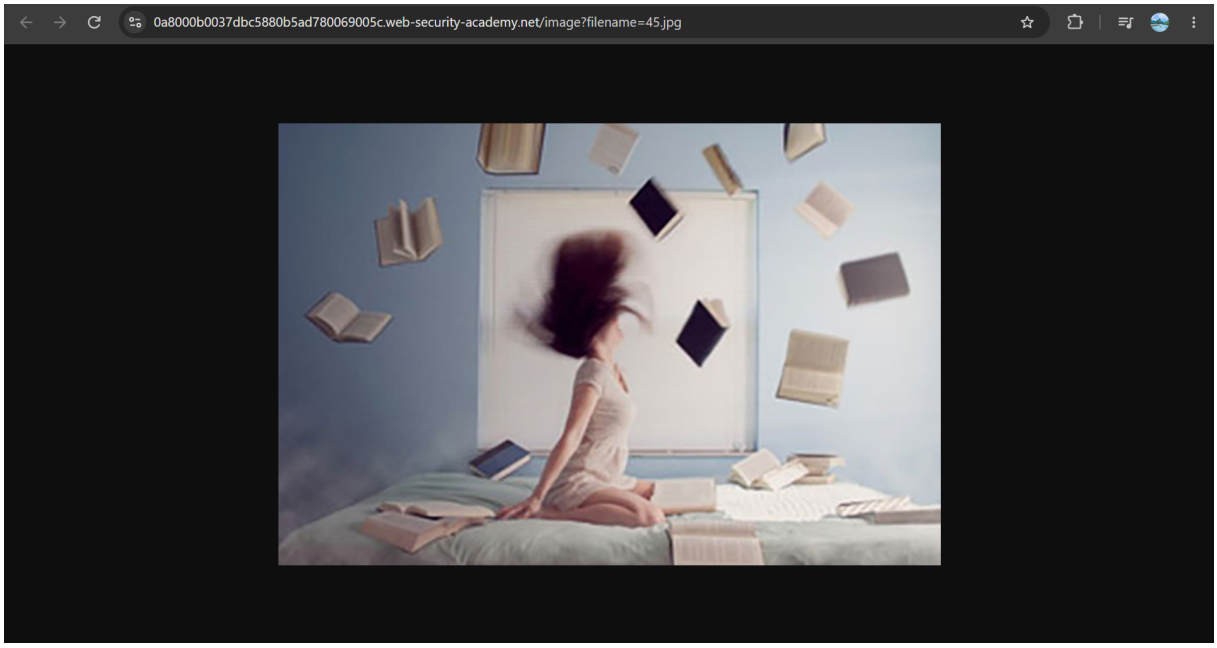


Figure 2: *The /image?filename=45.jpg endpoint requested directly, returning the raw image file.*

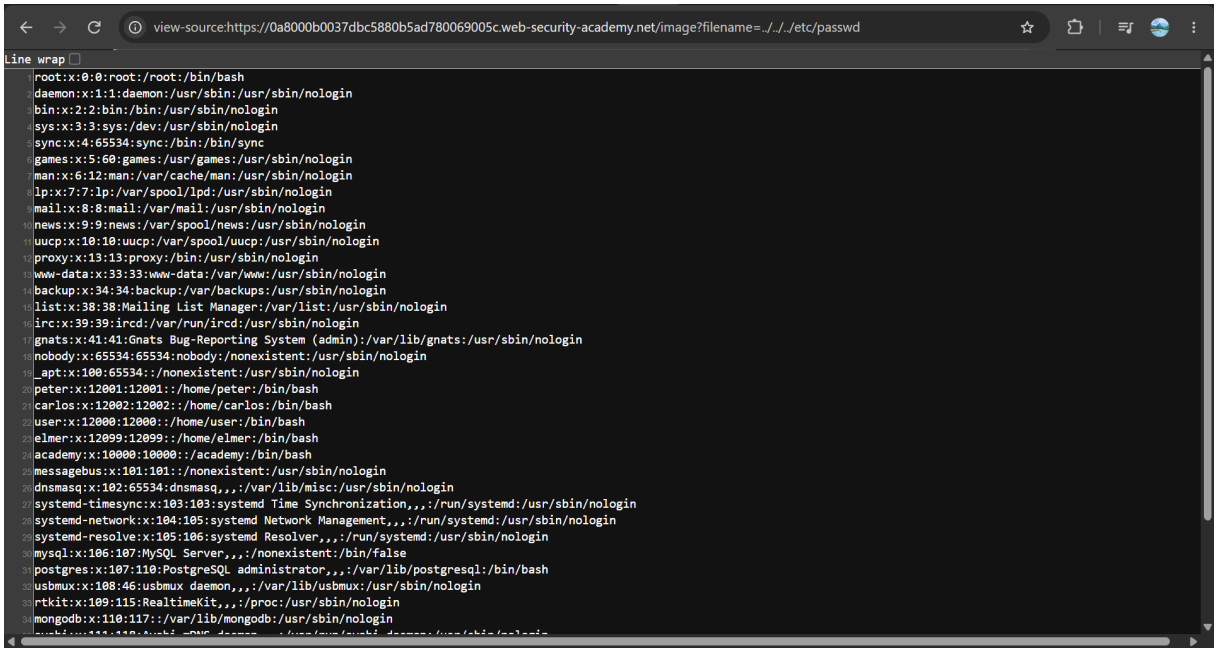


Figure 3: *Modified request /image?filename=../../../etc/passwd (view-source), returning the contents of the server's /etc/passwd file.*

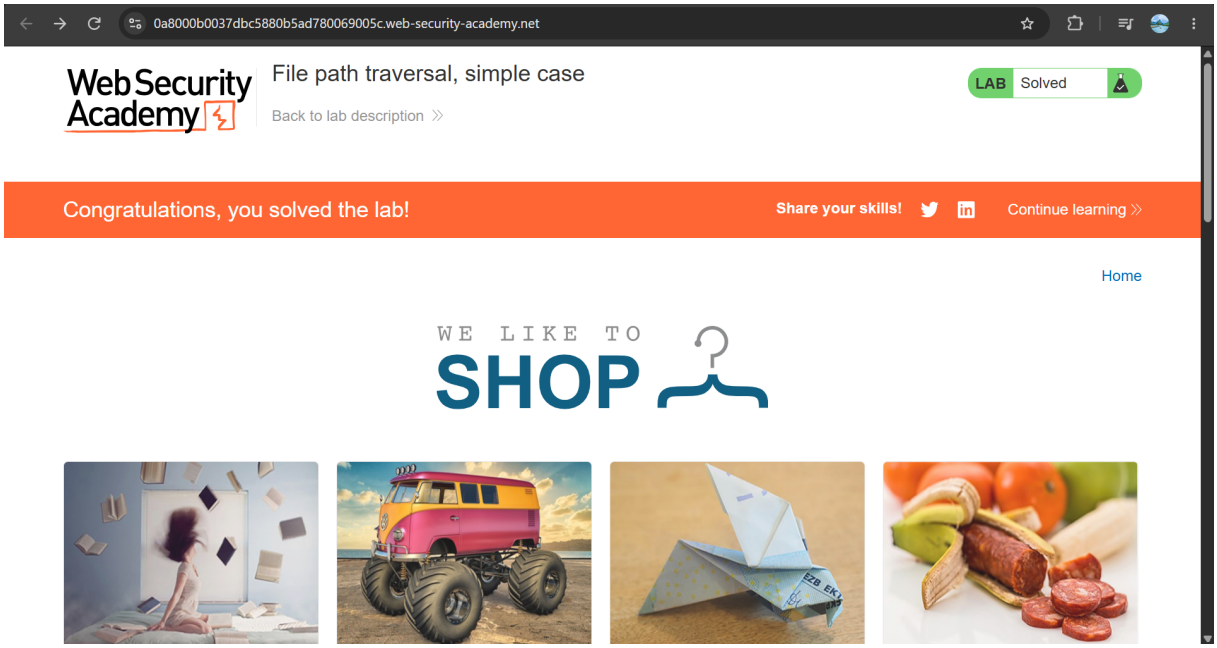


Figure 4: *Lab status changed to Solved after the traversal was confirmed.*

6. Impact

Path traversal allows an attacker to read files outside the directory the application intended to expose. Depending on what is reachable on the server, this can expose configuration files, source code, credentials, or sensitive system files like /etc/passwd as demonstrated here — and in some configurations can be combined with other flaws (e.g. file upload) to achieve remote code execution.

7. Remediation

- Avoid passing user input directly to filesystem APIs; instead, map a request to a file using a fixed, server-side lookup (e.g. an ID to a known filename) rather than trusting the client-supplied name.

- If a filename must be accepted from the client, strictly validate it against an allow-list of characters and reject any path separators or traversal sequences.
- After resolving the final file path, verify it still sits inside the intended base directory before reading it.

8. What I Learned

- How a filename parameter that looks harmless (e.g. for loading product images) can become a serious vulnerability if it is trusted without validation.
- Using view-source on the response is a simple way to confirm a traversal worked when the server would otherwise try to render the result as an image.
- Why mapping requests to files indirectly (through an ID or lookup table) is safer than accepting a raw filename from the client.

Declaration: I confirm that this report documents my own work and that all screenshots were taken by me during the tasks described.

Name: Maryam Batool Date: 1 November 2026